Quang-Vinh Dang
British University Vietnam
Hung Yen, Vietnam
vinh.dq4@buv.edu.vn

25 July 2026

The Editors
Computers & Security
Elsevier

Dear Editors,

I am pleased to submit my manuscript, **"Conformal Surprisal Fusion for Detecting Prompt-Injection Compromise in LLM Agent Traces,"** for consideration as a research article in *Computers & Security.*

Large language model agents that call external tools now read email, browse the web and move money on a user's behalf. Because they ingest untrusted content and fold it into the context that drives their next action, they are exposed to indirect prompt injection. Runtime monitors that watch only the black-box execution trace need no model access and no retraining, but the literature has converged almost entirely on one kind of evidence: whether untrusted text *looks like an instruction.* This paper asks what else the trace affords, how heterogeneous evidence should be combined, and where the information in a trace runs out.

The work makes four contributions. First, it introduces **SENTRY-Fuse**, a monitor that converts heterogeneous trace signals—one scoring the observation stream, two auditing the action stream—into conformal tail surprisals against a benign calibration split and fuses them by addition. The construction is scale-free, non-decreasing in every component and free of tuned signal weights, and the paper proves that the natural alternative of subtracting the benign training maximum is many-to-one and, for any attack class lying below that maximum, caps AUROC at one half. That is not hypothetical: an earlier, unpublished draft of this work did exactly that, at a cost of 0.25 AUROC and a confidently wrong explanation of the resulting failure. Second, action-side evidence is shown to be *complementary* rather than redundant: over 90 genuinely compromised trajectories, adding two action-side audits to the instruction signal raises AUROC from 0.937 to 0.954 ± 0.003 (paired $t = 4.9$) and cuts the across-draw standard deviation of recall from ± 0.357 to ± 0.005. I report the mean recall gain as *not* significant against that variability, because it is not. Third, I measure where trace evidence lives and draw a benchmark-design conclusion: AgentDojo's observation channel is close to saturated, because it delivers payloads through tool outputs a successful injection must have read, so corpora of this shape cannot contain a compromise invisible to a trace monitor and cannot test the hard case. I explicitly decline to convert this into an information-theoretic ceiling, and explain in the paper why an earlier draft was wrong to do so—the quantity is not identified, and at the strictest criterion the bound it yields is violated by my own measured true-positive rate.

I should be explicit that the paper does *not* claim to beat the state of the art. The strongest reported trace-only figure (95.75% true positives at 3.66% false positives) comes from a preprint version that later versions withdraw, was measured on a different corpus with a different agent, and I re-implemented no baseline on my own corpus. My numbers sit in the same regime, and I say so rather than constructing a comparison the evidence does not support.

I believe the work suits *Computers & Security* in particular. It is a security paper first: it defines a threat model, evaluates a defence against real attacks on real agent traces, and reports its limits rather than only its successes. It offers two things of direct use to others: a measurement showing that the benchmarks the field relies on cannot exhibit the hardest case, and a methodological warning about how results on a standard benchmark should be read. Its negative results are reported in full—four signals I implemented and rejected, two of which an earlier draft presented as part of the method, and the finding that a hand-picked threshold outperformed the anytime-valid machinery from which the project began.

All code, the trajectory corpora, the cached model-judge scores and the analysis scripts that regenerate every number, table and figure are publicly released, and the evaluation reproduces offline without access to any model API.

I confirm that this manuscript is original, has not been published previously and is not under consideration elsewhere. There are no competing interests and no external funding was received; as sole author I am responsible for all aspects of the work. Thank you for your consideration, and I look forward to the reviewers' comments.

Sincerely,

Quang-Vinh Dang